

המכון הטכנולוגי חולון

הפקולטה למדעים

מסמך מסכם — פרויקט גמר סמסטר יאלי

xAI & rAI comparison based on model alerted

XAI & RAI Comparative Analysis — Isolation Forest vs. Autoencoder on NSL-KDD

השוואת שני מודלי גילוי אנומליות (Isolation Forest, Autoencoder) על NSL-KDD דרך מודלי XAI/RAI קיימים

מוגש על ידי: לוטם קמחי, בעז עטייה

בהנחיית: אנדרי כוזוב

מסגרת: פרויקט גמר סמסטר יאלי — קורס מבוא לאבטחת סייבר מונחית בינה מלאכותית

תאריך הגשה: ספטמבר 2026

תקציר

פרויקט זה משווה באופן שיטתי בין שני מודלים לגילוי אנומליות — Autoencoder ו-Isolation Forest — הפועלים כמחקר עצמאי (offline), ללא כל תלות בפיילין SOC חי כלשהו. שני המודלים מאומנים על מערך הנתונים הציבורי NSL-KDD, מנבאים יחד על נתונים חדשים (סט הבדיקה המוחזק), והתוצאות שלהם מוזנות למודולי XAI ו-RAI קיימים בקוד המחקר — לא נבנים מחדש עבור כל מודל, אלא מיושמים בעקביות על שניהם כדי שהשוואה ביניהם תהיה הוגנת. התוצאות המתקבלות מושוות זו לזו כדי לבחון כיצד בחירת מודל הגילוי משפיעה לא רק על ביצועי הגילוי אלא גם על טיב ההסבר (XAI) ועל הערכת האחראיות (RAI) שמתקבלת בהמשך.

המחקר ממחיש שרשרת ברורה: NSL-KDD ← אימון שני המודלים ← חיזוי על נתונים חדשים ← מודולי XAI/RAI קיימים ← השוואת תוצאות. לכל אירוע, שני המודלים מייצרים evidence עצמאי — SHAP עבור Isolation Forest ושגיאת שחזור לכל feature עבור ה-Autoencoder — יחד עם "אות צולב" (cross-model signal) המאפשר לכל התראה להציג גם את פלט המודל השני עבור אותו אירוע. ממצא מרכזי שעלה מהניתוח: ל-Isolation Forest פער הוגנות (fairness gap) גבוה של 47.6% הנובע מפער חד ב-False Positive Rate בין תתי-קבוצות protocol_type (icmp לעומת tcp/udp), אשר גורם למדיניות ה-RAI לחסום כל התראת IF מהכלה אוטומטית ולדרוש אישור אנושי — בעוד שה-Autoencoder עומד בסף ההוגנות (7.2%) ולכן זכאי, בתנאים המתאימים, להכלה אוטומטית. ממצא זה מדגים כיצד בחירת מודל הגילוי משפיעה על ממשל ה-AI במעלה הזרם, מעבר לביצועי הגילוי הגולמיים בלבד.

תוכן עניינים

2	תקציר
3	תוכן עניינים
4	1. מבוא
4	1.1 רקע ובעיה
4	1.2 שאלת המחקר
4	1.3 מטרות הפרויקט
5	2. רקע תיאורטי
5	2.1 גילוי אנומליות ללא פיקוח
5	Isolation Forest
5	Autoencoder
5	ההבדל המהותי בין המודלים
5	2.2 בינה מלאכותית ניתנת להסבר (XAI)
5	2.3 בינה מלאכותית אחראית (RAI)
6	4. שיטת המחקר
6	4.1 מערך הנתונים — NSL-KDD
6	4.3 מתודולוגיית ההערכה
6	4.4 מתודולוגיית ה-XAI
6	4.5 מתודולוגיית ה-RAI
7	6. תוצאות
7	6.1 ביצועי המודלים על סט הבדיקה
8	6.2 מקור פער ההוגנות ב-Isolation Forest
8	6.3 ארבעת תרחישי השוואה
9	6.4 תובנות איכותניות מתגובות מודל השפה
11	7. דיון
11	7.1 בחירת המודל כהחלטת ממשל, לא רק כהחלטת דיוק
11	8. מסקנות
11	9. עבודה עתידית

1. מבוא

1.1 רקע ובעיה

מרכזי תפעול אבטחה (SOC) מודרניים נשענים יותר ויותר על מודלים סטטיסטיים ולמידת מכונה לזיהוי אנומליות בתעבורת רשת ובאירועי מערכת, שכן חתימות מבוססות-כללים אינן מספיקות מול איומים משתנים. עם זאת, שילוב בינה מלאכותית בשרשרת ההחלטה התפעולית — במיוחד כאשר תוצאת המודל עשויה להוביל להכלה אוטומטית (automated containment) — מעלה שתי בעיות יסוד:

- שקיפות (XAI): מנתח אנושי אינו יכול לבסס אמון בהתראה, ובוודאי לא לפעול לפיה באופן אוטומטי, מבלי להבין אילו features הובילו למסקנת המודל.
 - אחריותיות (RAI): מודל עשוי להציג ביצועים גבוהים בממוצע (Precision/Recall/F1) תוך שהוא סובל מהטיה חדה בתתי-אוכלוסיות מסוימות (למשל סוג פרוטוקול), מה שהופך הכלה אוטומטית המבוססת עליו למסוכנת, גם אם הציון הכללי שלו נראה תקין.
- הפרויקט הוא מחקר עצמאי (offline) המשווה בין שני מודלים שונים לחלוטין באופיים המתמטי — Isolation Forest ו-Autoencoder — ובוחרן כיצד כל אחד מהם מתורגם, תחת אותם מודולי XAI ו-RAI קיימים, לזוג שונה של "הסבר" ו"הערכת ממשל" עבור אותם אירועים בדיוק.

1.2 שאלת המחקר

שאלת המחקר שהנחתה את הפרויקט, כפי שגובשה מול המנחה, הייתה: כאשר סוכני ה-XAI וה-RAI מקבלים רק את נתוני האירוע שהפעיל את ההתראה, ללא מידע נוסף משלב הזיהוי, קשה לייחס הבדלים בפלט שלהם למודל עצמו — ולכן יש להעשיר את המידע שמועבר משלב הזיהוי למודולי ה-XAI/RAI ב-evidence שנוצר כבר בשלב הזה, כך שההבדלים בפלט ה-XAI/RAI יהיו ניתנים לייחוס ישיר לבחירת המודל, ולא לרעש הנובע ממידע חסר.

1.3 מטרות הפרויקט

- לאמן שני מודלים לגילוי אנומליות — Isolation Forest ו-Autoencoder — על מערך הנתונים הציבורי NSL-KDD, תחת אותה מתודולוגיית אימון והערכה.
- להריץ את שני המודלים המאומנים על נתונים חדשים (סט בדיקה מוחזק) ולהפיק עבור כל אירוע ציון אנומליה וסיווג.
- להזין את תוצאות החיזוי של שני המודלים למודולי XAI ו-RAI קיימים בקוד המחקר — evidence ברמת-feature (SHAP ל-IF, שגיאת שחזור ל-AE) ו"אות צולב" בין שני המודלים, כדי שההשוואה תהיה עקבית והוגנת.
- להזין את המידע המועשר למדיניות RAI מבוססת-metadata (Precision/Recall/FPR/Fairness Gap) ולמנוע מסקנות RAI המבוססות על התראה בודדת.
- להריץ ולתעד 4 תרחישי בדיקה (הסכמה/אי-הסכמה בין המודלים) ולהשוות את התוצאות שהתקבלו משני המודלים.
- להזין את התוצאה המועשרת למודל שפה מקומי (Llama 3.1 דרך Ollama) המפיק נרטיב בשפה טבעית לאנליסט SOC, כהדגמה של שימוש אפשרי בתוצאות

2. רקע תיאורטי

2.1 גילוי אנומליות ללא פיקוח

Isolation Forest

Isolation Forest הוא אלגוריתם מבוסס-עצים שאינו לומד "פרופיל של נורמליות" במפורש, אלא מנצל את העובדה שנקודות חריגות קל יותר לבודד (isolate) על ידי חלוקות אקראיות מאשר נקודות רגילות. ציון האנומליה נגזר ממספר הפיצולים הממוצע הנדרש לבידוד כל דגימה על פני יער של עצים אקראיים — ציון נמוך (מסלול קצר לבידוד) מעיד על חריגות גבוהה. במימוש הפרויקט נעשה שימוש ב-scikit-learn (IsolationForest, 100 עצים), מאומן אך ורק על דגימות "נורמליות" מתוך סט האימון (train-on-normal-only).

Autoencoder

Autoencoder הוא רשת נוירונים המאומנת לשחזר את קלט הקידוד (encoding) שלה עצמה, דרך צוואר בקבוק (bottleneck) בעל ממד מופחת. כאשר הרשת מאומנת רק על דגימות נורמליות, היא לומדת שחזור טוב עבורן — אך משחזרת בצורה גרועה דגימות שמבנה ה-feature שלהן שונה מהותית מהדפוס שנלמד. שגיאת השחזור (Reconstruction Error, לרוב MSE) משמשת כציון אנומליה.

ההבדל המהותי בין המודלים

שני המודלים מזהים "סטייה מנורמליות", אך המנגנון שונה לחלוטין: Isolation Forest מודד קלות בידוד גיאומטרית-סטטיסטית מבוססת פיצולים, בעוד Autoencoder מודד יכולת שחזור מבוססת-רשת עצבית. כתוצאה מכך, גם ה-evidence שכל מודל מסוגל להפיק שונה במהותו — עובדה שהמחקר מנצל כדי להשוות לא רק דיוק אלא גם את איכות ההסבר וההשלכות לממשל.

2.2 בינה מלאכותית ניתנת להסבר (XAI)

שכבת ה-XAI בפרויקט אינה "קופסה שחורה שנייה" — היא נגזרת ישירות מהמתמטיקה הפנימית של כל מודל:

- עבור Isolation Forest: נעשה שימוש ב-**SHAP TreeExplainer**, המספק ערכי Shapley מדויקים (לא קירוב) עבור אנסמבל עצים — כל feature מקבל תרומה מסומנת (חיובית/שלילית) לציון האנומליה של אותה דגימה ספציפית.
- עבור Autoencoder: נעשה שימוש בשגיאת שחזור ברמת-feature — $(x_i - \text{reconstruction}_i)^2$ — המזהה אילו features ספציפית "נראו הכי פחות נורמליים" לרשת עבור אותה דגימה. בשני המקרים נשמרים רק שלושת ה-features המשמעותיים ביותר (top-3) עבור כל אירוע, כדי לשמור על תמציתיות ההסבר המוצג למנתח האנושי ו/או למודל השפה במורד הזרם.

2.3 בינה מלאכותית אחראית (RAI)

שכבת ה-RAI בפרויקט אינה מבוססת על ציון האנומליה הבודד של אירוע מסוים, אלא על רשומת האמינות הגלובלית (track record) של המודל, שנמדדה פעם אחת על סט הבדיקה המוחזק (held-out test set):

- Precision / Recall / F1 — ביצועי סיווג כלליים.
 - False Positive Rate (FPR) — שיעור האזעקות השווא, קריטי בהערכת עומס תפעולי על אנליסטים.
 - Fairness Gap — פער ה-FPR המרבי בין תתי-קבוצות (proxy attribute — למשל protocol_type), כמדד להטיה בביצועי המודל על פני פלחי אוכלוסייה שונים.
- עקרון תכנון מרכזי: מדיניות ה-RAI (rai_policy_evaluator) קוראת אך ורק את רשומת האמינות הגלובלית של המודל — לעולם לא את ציון האנומליה הפרטני של האירוע. ההיגיון: אירוע בודד שנראה חריג אינו אמור לבטל את מה שכבר ידוע על אמינות המודל בכללותו. כך, אם המודל ידוע כבעל פער הוגנות גבוה, כל התראה שהוא מייצר — גם אם הציון שלה נמוך יחסית — תיחסם מהכלה אוטומטית ותדרוש אישור אנושי.

4. שיטת המחקר

4.1 מערך הנתונים — NSL-KDD

מערך הנתונים NSL-KDD (גרסה מתוקנת של KDD Cup 1999) הוא מערך תקן להערכת מערכות גילוי חדירה, ומכיל רשומות תעבורת רשת מתוגות כ"נורמלי" או כאחד מסוגי התקיפה. בפרויקט נעשה שימוש בקבצי KDDTrain+.txt ו-KDDTest+.txt. לאחר עיבוד מקדים — נרמול (StandardScaler) ל-38 features מספריים וקידוד One-Hot ל-3 features קטגוריאליים (protocol_type, service, flag) — מתקבל וקטור feature סופי בממד 121.

הפיצול לאימון/בדיקה הוא 70/30 באופן stratified עם seed קבוע (42), כך שהתוצאות ניתנות לשחזור מלא.

4.3 מתודולוגיית ההערכה

שני המודלים מוערכים באמצעות פונקציה אחידה (unified_evaluate) המבטיחה שהבדלים בתוצאות ניתנים לייחוס למודל בלבד ולא לשיטת מדידה שונה. נקודת המפתח המתודולוגית: סף הסיווג (threshold) נגזר מהתפלגות ציוני האנומליה של סט הבדיקה עצמו, ולא מחיפוש ה-F1 הטוב ביותר על סט הבדיקה. חיפוש כזה היה "מדליף" מידע מתיוגי הבדיקה לבחירת המודל, ומנפח את שני המודלים באופן לא-שווה.

4.4 מתודולוגיית ה-XAI

לכל אירוע בודד, מופקת רשימת שלושת ה-features המשמעותיים ביותר (top-3) המסבירים את ציון האנומליה: עבור Isolation Forest — ערכי SHAP מדויקים דרך TreeExplainer עבור Autoencoder — שגיאת שחזור ברמת-feature. הפונקציות המחשבות evidence אלו נשארו ללא שינוי לאורך כל שלבי הפיתוח, לפי דרישת המנחה שלא לשנות את לוגיקת ה-XAI/RAI הקיימת.

4.5 מתודולוגיית ה-RAI

Fairness Gap ו-Precision, Recall, F1, FPR מחושבים פעם אחת בשלב האימון (Phase 1) על סט הבדיקה המלא, ונשמרים ב-manifest.json כ-metadata גלובלי לכל מודל. ה-Fairness Gap מחושב כפער ה-FPR המרבי בין תתי-קבוצות protocol_type, ומייצג בדיקת פער-ביצועים (subgroup performance-disparity check) ולא ביקורת הוגנות דמוגרפית. מדיניות הממשל (rai_policy_evaluator) מפעילה שני ספים קבועים:

```
FPR_STRICT_THRESHOLD = 0.10
FAIRNESS_GAP_STRICT_THRESHOLD = 0.10
```

אם התחזית היא "נורמלי" — שאלת ההכלה אינה רלוונטית. אחרת, אם $FPR > 10\%$ או $Fairness\ Gap > 10\%$ → נדרש אישור אנושי ואין הכלה אוטומטית; אחרת → הכלה אוטומטית מותרת.

6. תוצאות

6.1 ביצועי המודלים על סט הבדיקה

הטבלה והגרף הבאים מציגים את מדדי הביצועים והממשל שנמדדו על סט הבדיקה המוחזק של NSL-KDD, עבור שני המודלים תחת אותה מתודולוגיית סף (ראו פרק 4.3):

סף סיווג	Fairness Gap	FPR	F1	Recall	Precision	מודל
0.108	0.476	0.091	0.901	0.901	0.901	Isolation Forest
0.047	0.072	0.086	0.907	0.907	0.907	Autoencoder

טבלה 3: מדדי ביצועים והוגנות — Isolation Forest מול Autoencoder

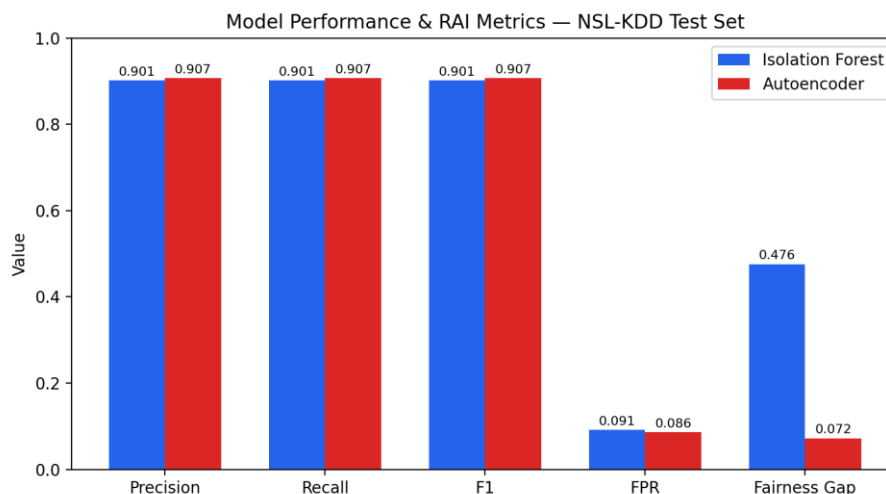
הארה מתודולוגית: התכנסות מדדי ה-Precision, Recall ו-F1

בבחינת טבלת התוצאות, ניכר כי עבור כל מודל, ערכי ה-Precision, Recall ו-F1 זהים לחלוטין. חשוב להדגיש כי אין מדובר בשגיאת חישוב או בצירוף מקרים, אלא בארטיפקט מתמטי מכיוון הנובע ממתודולוגיית ההערכה המבוקרת של המחקר:

- **מניעת זליגת נתונים (Data Leakage):** כדי להימנע מבחירת סף (Threshold) שרירותי המקסם את ה-F1 בדיעבד, פרמטר ה-contamination-קובע כך שיתאים לשיעור האנומליות האמיתי בסט הבדיקה. (Label prior)
- **ההשפעה המתמטית (FP = FN):** כתוצאה מקיבוע זה, הקוד מאלץ את המודל לייצר כמות התראות כוללת השווה לכמות התקיפות האמיתיות. מצב זה מחייב מתמטית שגודל קבוצת התראות השווא נוסחאות ה-Precision ו-Recall מתכנסות בהכרח לאותו ערך, ונועלות איתן את ציון ה-F1.

משמעות הממצא לתזה המרכזית של הפרויקט:

התכנסות המדדים מוכיחה את הטענה המרכזית של מחקר זה: בסביבה מבוקרת, ביצועי הגילוי היבשים (F1/Precision/Recall) של מודלים שונים יכולים להיראות זהים לחלוטין. לכן, אי אפשר להעריך מודל אבטחה רק על סמך "כמה התקפות הוא תפס". ההבדל הקריטי שמכריע האם המודל מתאים לשימוש מבצעי ב-SOC לא נמצא בשורת הביצועים, אלא במה שקורה מתחת לפני השטח — **היכולת להסביר את ההחלטה (XAI) והיעדר הטיה מובנית (RAI)**, כפי שבא לידי ביטוי בפער ההוגנות החרגי שהתגלה במודל ה-Isolation Forest.

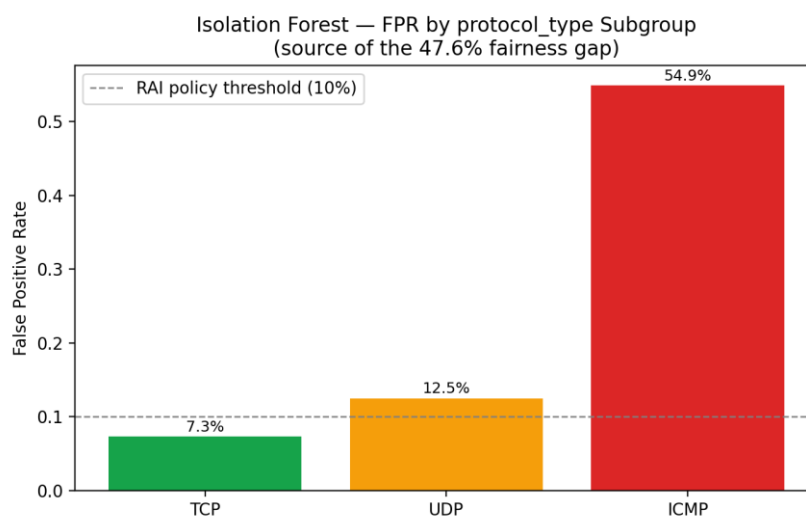


גרף 1: השוואת מדדי ביצועים ו-RAI בין שני המודלים

שני המודלים מציגים ביצועי סיווג גולמיים (Precision/Recall/F1) דומים מאוד. ההבדל הדרמטי מופיע במדד ה-Fairness Gap: עבור Isolation Forest לעומת 7.2% בלבד עבור Autoencoder — פער של פי כ-6.6, שכפי שיוצג בהמשך, קובע הלכה למעשה את יכולת ההכלה האוטומטית של כל מודל.

6.2 מקור פער ההוגנות ב-Isolation Forest

ניתוח לפי תת-קבוצות protocol_type חשף שפער ההוגנות של Isolation Forest נובע מ-FPR גבוה במיוחד בתעבורת ICMP, לעומת TCP ו-UDP:



גרף 2: FPR של Isolation Forest לפי תת-קבוצות protocol_type — מקור פער ההוגנות של 47.6%

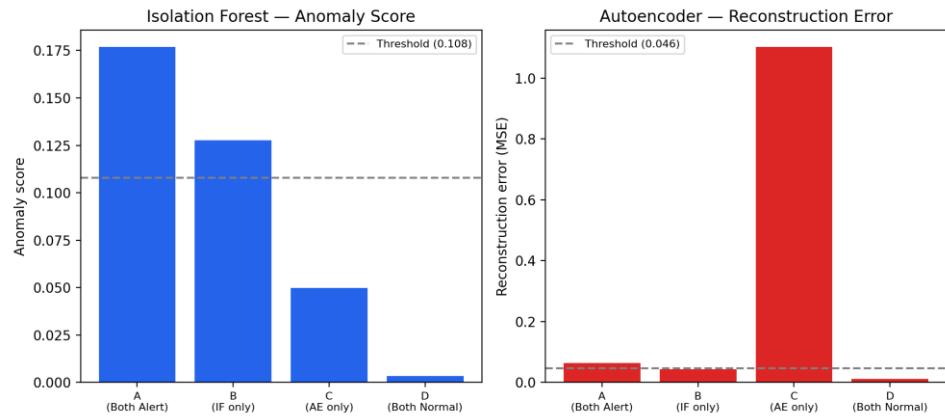
פער זה (7.3% ב-TCP מול 54.9% ב-ICMP) הוא שמניב Fairness Gap של 47.6% ($47.6\% \approx 7.3\% - 54.9\%$), החורג משמעותית מסף המדיניות של 10%. כתוצאה מכך, כל התראת Isolation Forest — ללא תלות בציון האנומליה הספציפי שלה — נחסמת ממדיניות ההכלה האוטומטית ומועברת לאישור אנושי.

6.3 ארבעת תרחישי ההשוואה

לצורך בחינה איכותנית של שרשרת ה-RAI → XAI → Evidence → Model, הוגדרו ונבדקו ארבעה תרחישים המכסים את כל שילובי ההסכמה/אי-ההסכמה האפשריים בין שני המודלים על אירועי בדיקה אמיתיים מתוך NSL-KDD:

החלטת ממשל	מדדי RAI	Evidence מרכזי (XAI)	תחזית ומדד	מודל מפעיל	תרחיש
נדרש אישור אנושי — פער הוגנות חורג מ-10%	FPR 9.1% Gap 47.6%	dst_host_srv_diff: - : protocol_icmp 1.42 1.21-	Anomaly (0.1770)	Isolation Forest	A — הסכמה (שני המודלים מתריעים)
הכלה אוטומטית מותרת — עומד בסף האמון	FPR 8.6% Gap 7.2%	srv_diff_host: +2.23 diff_srv_rate: +0.86	Anomaly (0.0638)	Autoencoder	A
נדרש אישור אנושי — סיכון לעייפות התראות	FPR 9.1% Gap 47.6%	service_private: - : same_srv_rate 1.14 0.96-	Anomaly (0.1276)	Isolation Forest	B — אי-הסכמה (בלבד IF)
אין פעולה — המודל מסווג כנורמלי	FPR 8.6% Gap 7.2%	: dst_host_diff_srv 1.12+ : service_private 0.73+	Normal (0.0437)	Autoencoder	B
אין פעולה — המודל מסווג כנורמלי	FPR 9.1% Gap 47.6%	service_telnet: -1.78 logged_in: -0.43	Normal (0.0498)	Isolation Forest	C — אי-הסכמה (בלבד AE)
הכלה אוטומטית מותרת — אנומליה חזקה עם מדדי אמון בטוחים	FPR 8.6% Gap 7.2%	num_root: +47.33 : num_compromised 40.79+	Anomaly (1.1034)	Autoencoder	C
אין פעולה — הסכמה על תקינות	FPR 9.1% Gap 47.6%	dst_same_port: -1.35 dst_count: -0.17	Normal (0.0033)	Isolation Forest	D — הסכמה (שני המודלים נורמליים)
אין פעולה — הסכמה על תקינות	FPR 8.6% Gap 7.2%	: dst_host_count 0.26+ : dst_same_port 0.17+	Normal (0.0119)	Autoencoder	D

טבלה 4: פירוט מלא של 4 תרחישי החשודה Evidence — (A-D), מדדי RAI והחלטת ממשל



גרף 3: ציוני האנומליה/שגיאת השחזור בארבעת התרחישים, ביחס לסף הסיווג של כל מודל

6.4 תובנות איכותניות מתגובות מודל השפה

- תרחיש A** — מודל השפה זיהה נכונה את ההסכמה בין שני המודלים והשתמש בה כדי לנמק רמת ביטחון גבוהה בסיווג, כפי שנדרש מהמשימה הרביעית שנוספה ל-prompt.
- תרחיש B** — מודל השפה ציין במפורש שה-Autoencoder חזה "נורמלי" עבור אותו אירוע, ותלה זאת באפשרות לרעש או לחריגות ספציפיות ל-feature בודד ולא לפגם מהותי באחד המודלים — הערכה סבירה, אך מדגישה בדיוק את מקרה אי-ההסכמה שראוי לבדיקה אנושית.
- תרחיש C** — שגיאות השחזור הגדולות ביותר (num_root, num_compromised) הן אינדיקטורים קלאסיים להסלמת הרשאות (privilege escalation) — "סיפור" איכותני שונה לחלוטין מהאות מבוסס-המגניטודה של Isolation Forest. מודל השפה המליץ ליישב בין פלטי שני המודלים לפני פעולה — המלצה סבירה שהמדיניות האוטומטית עצמה אינה אוכפת.

- **תרחיש D** — הסכמה מלאה על תקינות הובילה לביטחון גבוה בסיווג הבניין, ללא צורך בהתערבות.

7. דיון

7.1 בחירת המודל כהחלטת ממשל, לא רק כהחלטת דיוק

הממצא המרכזי של המחקר הוא שבחירת מודל הגילוי אינה משפיעה רק על Precision/Recall — היא קובעת בפועל את מסלול הממשל התפעולי של כל התראה. למרות ש-Isolation Forest ו-Autoencoder מציגים ביצועי סיווג גולמיים כמעט זהים (הפרש F1 של כ-0.006 בלבד), פער ההוגנות שלהם שונה פי כ-6.6 — כך שבפועל, כל התראת Isolation Forest חסומה מהכלה אוטומטית ללא תלות באיכותה, בעוד Autoencoder זוכה לגמישות תפעולית רבה יותר. תוצאה זו לא הייתה נגלית לו נבחן רק מדד ביצועים כללי אחד (כגון F1 או ROC-AUC), והיא ממחישה מדוע נדרשת שכבת RAI נפרדת ומפורשת המבוססת על ניתוח תתי-אוכלוסיות.

8. מסקנות

הפרויקט השיג את מטרותיו המרכזיות: שני מודלים לגילוי אנומליות — Isolation Forest ו-Autoencoder — אומנו על NSL-KDD, הופעלו על נתונים חדשים, והוזנו למודולי XAI/RAI קיימים תחת מתודולוגיה אחידה לחלוטין (אותו split, אותו seed, אותה שיטת סף, אותה שיטת top-3 evidence) כך שהשוואה ביניהם הוגנת. העשרת המידע שמוזן למודולים — cross-model signal ו-evidence ברמת feature לשני המודלים — מימשה במלואה את הדרישה, כולל את ההרחבה הרצויה (SHAP ל-Isolation Forest).

שרשרת המעקב RAI assessment → XAI interpretation → Evidence → Detection → Model מאפשרת להראות בבירור שממצאי ה-XAI וה-RAI ניתנים לייחוס ישיר לבחירת המודל: Autoencoder, על אף ביצועי סיווג כמעט זהים ל-Isolation Forest, מציג פער הוגנות נמוך משמעותית ולכן מקבל יתרון ממשלי ברור — יכולת הכלה אוטומטית בתנאים המתאימים, בעוד Isolation Forest חסום מכך באופן שיטתי. תוצאה זו ממחישה עיקרון רחב יותר: שבחירת מודל למערכת AI תפעולית היא גם החלטת ממשל, לא רק החלטת דיוק.

9. עבודה עתידית

- **הרחבה למערך נתונים שני** — הפעלה מלאה של השוואת Credit Card Fraud (קיימת כבר ב-run_comparison.py) דרך שלבי ה-LLM המלאים, לבחינת האם ממצא ה-Fairness Gap חוזר על עצמו במבנה נתונים שונה לחלוטין.
- **הערכה כמותית של תגובות מודל השפה** — בניית מדגם רחב יותר של תגובות והערכתן באופן שיטתי (למשל דירוג אנושי או metric עקביות אוטומטי), מעבר לניתוח האיכותני שבוצע על 4 התרחישים.
- **בדיקת רגישות לסף המדיניות** — בחינת השפעת שינוי FPR_STRICT_THRESHOLD / FAIRNESS_GAP_STRICT_THRESHOLD (כיום 10% לשניהם) על שיעור ההתראות הדורשות אישור אנושי, כדי לאפשר כיוון מודע-trade-off בין עומס אנליסטים לסיכון תפעולי.
- **שילוב בפיפליין החי** — בחינת מסלול לחיבור ההעשרה שפותחה במודול המחקר (offline) לתוך morpheus_lite_detector.py ו-agent_orchestrator.py של המעבדה החיה, תוך שמירה על עקרון ההפרדה שנשמר עד כה.

1. ייצור הראיות – (Evidence) איך המודלים מסבירים את עצמם? שכבת ה-xAI-

כדי שצוות האבטחה יסמוך על התראה, המודל חייב לספק "ראיות" מתמטיות שמסבירות למה הוא זיהה אנומליה. מכיוון ששני המודלים עובדים בצורה שונה לחלוטין, כל אחד מייצר ראיות בדרך אחרת:

Isolation Forest (IF) בעזרת SHAP: המודל הזה מזהה חריגות על ידי בניית עצי החלטה שמבודדים נתונים קיצוניים. הראיות שלו מחושבות בעזרת כלי מתמטי בשם SHAP, שמצביע בדיוק על המאפיין הספציפי שחרג משמעותית מהנורמה) למשל: "ההתראה הופעלה כי משתנה ה-src_bytes היה עצום."

Autoencoder (AE) בעזרת שגיאת שחזור (Reconstruction Error): מודל למידת עומק שלומד איך נראית תעבורה נורמלית ומנסה "לשחזר" כל נתון שנכנס אליו. אם הוא נכשל בשחזור, סימן שזו אנומליה. הראיות שלו מבוססות על בדיקה איזה מאפיין ספציפי המודל הכי התקשה לשחזר) למשל: "הנתונים נראים רגילים, אבל השילוב של שעת ההתחברות והפרוטוקול שבר את התבנית, ולכן שגיאת השחזור של עמודת ה-Protocol קפצה."

2. אות צולב (Cross-model signal)

מה זה אומר: כאשר אנליסט פותח התראה שהקפיץ מודל א' למשל, Isolation Forest) המערכת מציגה לו באותו מסך גם מה הייתה דעתו של מודל ב' (Autoencoder) על אותו אירוע בדיוק.

המשמעות: האנליסט מקבל תמונה מלאה ויכול להבין האם יש הסכמה מלאה בין המודלים (מה שמעלה את רמת הביטחון שזו תקיפה אמיתית) או שיש חילוקי דעות (אחד רואה תקיפה, השני חושב שזה משתמש לגיטימי).

3. פער ההוגנות (Fairness gap) ו-Fairness Rate -False Positive Rate

זהו הממצא המחקרי המרכזי שלכם.

False Positive Rate (FPR): מצב שבו המודל טועה ומסמן תעבורה תמימה ולגיטימית כתקיפה (התראת שווא).

פער הוגנות (Fairness Gap): מדד שבודק האם המודל עושה את הטעויות שלו באופן שווה, או שהוא "מפלה" קבוצות מסוימות.

מה מצאתם: גיליתם שמודל ה" Isolation Forest-שונה" תעבורת ICMP הוא טועה ומסמן תעבורת ICMP לגיטימית כתקיפה בתדירות הרבה יותר גבוהה מאשר תעבורת TCP/UDP לגיטימית. הפער הזה עומד על 47.6% – זהו מודל מוטא מאוד! לעומתו, ה Autoencoder-מאוזן והוגן הרבה יותר, עם פער של 7.2% בלבד.

4. השפעת ה-RAI בינה מלאכותית אחראית)

כאן באה לידי ביטוי שכבת המדיניות. ה-RAI הוא ה"מנהל" שקובע מה מותר למערכת לעשות.

בגלל ש Isolation Forest-מוטה (Bias): מנהל ה-RAI קובע שמודל עם פער הוגנות כזה ועם נטייה להתראות שווא על פרוטוקולים מסוימים הוא מסוכן. לכן, נאסר עליו לחסום תעבורה אוטומטית) הכלה אוטומטית / Containment) כל התראה שלו חייבת לעבור אישור ידני של אנליסט אנושי כדי לא לפגוע ברציפות העסקית.

בגלל ש-Autoencoder-הוגן: ה-RAI-מזהה שהמודל יציב, מדויק ואינו מוטא. לכן, ה-RAI-סומך עליו ומאפשר לו לחסום איומים באופן אוטומטי.

5. משמעות המחקר(AI Governance)

המשפט האחרון מסכם את כל התזה: בדרך כלל, חוקרים מסתכלים רק על "האם המודל זיהה את התקיפה או לא" (ביצועים גולמיים). הפרויקט שלכם מוכיח שבחירת המודל משפיעה על ניהול הארגון כולו (ממשל ה-AI) – מודל יכול להיות מדויק יחסית, אבל אם הוא מוטא, הוא ישתק את צוות ה-SOC כי הוא יחייב אותם לאשר ידנית כל פעולה.